# *Data Subject Deletion Rights*

## Question 1:

*Recall the examples in the FIPs lecture as a starting point for this topic. What are the similarities and differences in the data subject's rectification and deletion rights across GDPR, CCPA and PIPEDA?*

**Answer**

**Similarities and Differences in Data Subject's Rectification and Deletion Rights**

**Similarities**

**Right to Rectification:**

GDPR: Individuals can request the correction of inaccurate personal data without undue delay. **[CORRECT]**

CCPA: Consumers can request a business to correct inaccurate personal information about them. **[CORRECT]**

PIPEDA: Individuals can request the correction of their personal information and have the right to challenge the accuracy of the data. **[CORRECT]**

**Right to Deletion:**

GDPR: Known as the "right to be forgotten," individuals can request the deletion of personal data when it is no longer necessary or when they withdraw consent. **[NOT NUANCED]**

**Annotation:** *While this is technically correct, it's incomplete and oversimplified. GDPR Article 17 lists SIX grounds for deletion, not just two: (1) data no longer necessary, (2) withdrawal of consent, (3) objection to processing, (4) unlawful processing, (5) legal obligation to erase, and (6) data collected from children. The LLM only mentions two of the six grounds. Also, there are important exceptions where deletion can be refused (e.g., for legal compliance, public interest, scientific research).*

CCPA: Consumers can request the deletion of their personal information collected by businesses, with certain exemptions. **[NOT NUANCED]**

**Annotation:** *This is technically correct but very vague. The phrase 'with certain exemptions' doesn't tell us much. The CCPA has 11 specific exemptions to the deletion right (Section 1798.105(d)), including completing transactions, detecting security incidents, complying*

*with legal obligations, and enabling internal uses. Being more specific about these exemptions would make this more useful.*

PIPEDA: Individuals have the right to request the deletion of their personal information when it is no longer needed for the purposes for which it was collected. **[NOT NUANCED]**

**Annotation:** *This is somewhat accurate but lacks important nuance. PIPEDA doesn't explicitly provide a 'right to deletion' like GDPR does. Instead, it requires organizations to only retain data as long as necessary (Principle 4.5). Individuals can request deletion, but organizations may refuse if they have legitimate business or legal reasons to retain the data. This is a significant difference from GDPR that the LLM fails to highlight.*

**Differences**

| ASPECT | GDPR | CCPA | PIPEDA |
|---|---|---|---|
| Scope of Applicability | Applies to data controllers and processors in the EU. | Applies to for-profit businesses over a certain size operating in California. | Applies to private sector organizations handling personal data in Canada. |
| Conditions for Rectification | No specific conditions are set; requests should be handled promptly. | Requests must be verified before action. | Organizations must respond within a reasonable time frame. |
| Conditions for Deletion | Specific grounds for data retention must be met to deny deletion requests. | Certain exemptions, such as compliance with a legal obligation, may apply. | Organizations may retain data if needed for specific purposes, even after deletion is requested. |
| Enforcement Mechanism | Fines and penalties enforced by supervisory authorities in EU member states. | Enforcement through California Attorney General; potential civil penalties. | Enforcement by the Office of the Privacy Commissioner of Canada, with options for individuals to file complaints. |

**[INCORRECT / NOT NUANCED]**

**Annotation:** *The LLM labels this table as a table highlighting the differences between GDPR, CCPA, and PIPEDA but the language in the table entries is so vague that only the first and last rows show any differences. This framing incorrectly implies that only under CCPA do deletion and rectification requests need to be verified.*

**Key Observations**

Enforcement: Under GDPR, enforcement is stricter, with significant penalties for non-compliance. The CCPA has more focused enforcement by state authorities, while PIPEDA relies on federal oversight but allows for individual complaints. **[CORRECT]**

Consumer Rights: CCPA emphasizes consumer rights in the context of businesses, while GDPR presents a more comprehensive framework focused on broader individual rights. PIPEDA balances individual rights with organizational objectives. **[IDK]**

**Annotation:** *This statement is very vague and doesn't provide actionable information. What does 'emphasizes consumer rights in the context of businesses' mean compared to 'broader individual rights'? What specific differences exist? The phrase 'balances individual rights with organizational objectives' is generic and could apply to any privacy law. I would need to look up specific examples of how these laws differ in their approach to individual rights to properly evaluate this claim.*

Clarity and Ease of Access: GDPR provides a clearer, more formal structure for individuals to follow when exercising their rights. CCPA's framework is less formalized, whereas PIPEDA requires organizations to provide methods for individuals to access and correct their information. **[NOT NUANCED]**

**Annotation:** *The claim about GDPR being clearer is subjective. GDPR Article 12 requires responses within one month, provides detailed requirements for identity verification, and mandates specific information in responses. CCPA requires responses within 45 days (extendable to 90). However, saying 'CCPA's framework is less formalized' is vague - what specifically is less formal? The statement about PIPEDA is incomplete - it doesn't mention the specific requirements or timelines. This needs more concrete details.*

These similarities and differences highlight the varying approaches taken by different jurisdictions in protecting data subject rights concerning rectification and deletion of personal data. **[IRRELEVANT]**

**Annotation:** *This is a generic concluding sentence that doesn't add any new information. It's filler content that could be removed without losing any substance. The question asked for specific similarities and differences, not a meta-observation about the comparison itself.*

## Question 2:

*Explain the architectures of systems used to implement subject deletion rights. What features would they have?*

**<u>Answer</u>**

**System Architectures**

**Centralized Data Management System**

*Overview: A single repository stores all personal data in one location.* **[CORRECT]**

**Features:**

User Management: A unified interface for users to manage their data and deletion requests. **[CORRECT]**

Data Inventory: A comprehensive catalog of all personal data collected and processed. **[CORRECT]**

Access Controls: Role-based access to ensure that only authorized personnel can manage data deletion requests. **[CORRECT]**

Audit Logs: Recording all deletion requests and actions for compliance and accountability. **[CORRECT]**

**Decentralized Data Architecture**

*Overview: Data is distributed across multiple databases or services*. **[CORRECT]**

**Features:**

Data Mapping: Tools to identify where personal data resides across different systems. **[CORRECT]**

Interoperable APIs: Application programming interfaces (APIs) to facilitate communication between disparate systems and manage deletion requests. **[CORRECT]**

Synchronization Mechanisms: Ensure that data deletions are consistent across various databases or microservices. **[CORRECT]**

Notification System: Alerts users when their deletion requests are completed. **[CORRECT]**

**Blockchain-Based System**

*Overview: Utilizes a distributed ledger to manage personal data*. **[NOT NUANCED]**

**Annotation:** *This is problematic. Blockchain is fundamentally immutable - data cannot be deleted once written to the blockchain. This directly conflicts with the 'right to deletion.' While some blockchain implementations claim to support deletion through techniques like chameleon hashing or storing only encrypted data (and deleting keys), these are complex workarounds. The LLM presents this as a viable architecture without acknowledging the fundamental tension between blockchain immutability and deletion rights.*

**Features:**

Immutable Record Keeping: Ensure that records of deletion requests cannot be tampered with, providing a transparent audit trail. **[INCORRECT]**

**Annotation:** *This is contradictory. If the system is for implementing deletion rights, you need to DELETE data, not make it immutable. While it's true that blockchain can provide an immutable audit log of REQUESTS, you still need a separate system to actually delete the personal data. The LLM is confusing logging deletion requests with actually deleting data.*

Smart Contracts: Automated execution of deletion requests based on predefined conditions. **[IDK]**

**Annotation:** *I don't know enough about how smart contracts could implement actual data deletion. Smart contracts can execute logic automatically, but how would they delete data from an immutable ledger? This seems theoretically possible for triggering deletion in off-chain systems, but the LLM doesn't explain the mechanism. I would need to research examples of smart contracts being used for GDPR-compliant deletion.*

User Control: Decentralized identity management that allows individuals to control their data directly. **[NOT NUANCED]**

**Annotation:** *This is vague. 'Control their data directly' sounds good but doesn't explain HOW deletion would work in an immutable system. Decentralized identity (like self-sovereign identity) is about authentication and authorization, not necessarily data deletion. The LLM is conflating different concepts.*

**Hybrid Approach**

*Overview: Combines elements of centralized and decentralized architectures.* **[CORRECT]**

**Features:**

Unified Data Access Point: A central interface that interacts with multiple backend systems for data retrieval and deletion. **[CORRECT]**

Data Redundancy Check: Regular audits to identify and eliminate redundant data across various systems. **[NOT NUANCED]**

**Annotation:** *This is a good practice but vague. What tools are used? How often? The concept is correct - you want to identify duplicate copies of data to ensure complete deletion - but more specifics would be helpful.*

Flexible API Integrations: Allows for integration with other services while maintaining data privacy and governance. **[NOT NUANCED]**

**Annotation:** *This is very vague. What makes an API integration 'flexible'? How does it maintain 'data privacy and governance'? This reads like marketing language without technical substance.*

**Essential Features for Subject Deletion Systems**

User Interface for Requests: An intuitive dashboard where users can submit deletion requests easily. **[CORRECT]**

Verification Mechanism: Procedures to verify the identity of users making deletion requests to prevent unauthorized access. **[CORRECT]**

Compliant Workflows: Clearly defined workflows that align with legal obligations, ensuring timely processing of deletion requests. **[CORRECT]**

Data Retention Policies: Policies that dictate data retention times and conditions under which data can be retained even after deletion requests. **[CORRECT]**

Notification System: Alerts to inform users of the status of their deletion requests and confirmations when completed. **[REPEATED]**

**Annotation:** *This was already mentioned under 'Decentralized Data Architecture' above. The LLM is repeating the same feature.*

Audit and Compliance Reporting: Tools for generating reports to demonstrate compliance with data protection regulations and accountability measures. **[CORRECT]**

Data Destruction Methods: Secure methods for permanently deleting data, such as cryptographic erasure or physical destruction for hardware. **[CORRECT]**

User Support: Access to customer support for inquiries related to data deletion, providing guidance and assistance. **[CORRECT]**

In conclusion, implementing systems for subject deletion rights requires a careful balance between usability, security, and compliance with regulations. By incorporating these architectural elements and features, organizations can foster trust and transparency while upholding individual rights. **[IRRELEVANT]**

**Annotation:** *Generic concluding paragraph that doesn't add substance. This is filler text that could be removed.*

## Question 3:

*What are challenges in implementing data subject deletion rights? What happens if a data item gets accidentally deleted or the wrong data subject's item gets deleted? What about deleting data in backups — is this required? How can the architectures of systems used to implement subject deletion rights (discussed in the question above) handle these challenges?*

**Answer**

**Key Challenges**

Data Mapping and Identification: Identifying all instances of personal data across various databases can be complex, especially in decentralized architectures. **[CORRECT]**

Verification Processes: Implementing robust identity verification methods to ensure that deletion requests are legitimate without creating friction for legitimate users can be challenging. **[CORRECT]**

Legal and Compliance Issues: Navigating various legal frameworks and ensuring compliance with differing regulations (like GDPR, CCPA) can be complicated. **[CORRECT]**

Retention Policies: Balancing data retention laws with deletion requests can create conflicts. Some data may need to be retained for legal or regulatory reasons even after a request is made. **[CORRECT]**

System Complexity: Integrating deletion capabilities into existing systems, especially in legacy environments, may require significant resources and redesign. **[CORRECT]**

Employee Training: Ensuring staff are knowledgeable about policies and procedures related to data deletion to avoid errors. **[CORRECT]**

**Accidental or Incorrect Deletion of Data**

Accidental Deletion: Accidental deletion of a data item can disrupt operations, lead to loss of valuable information, and potentially violate legal obligations if the deleted data is required for regulatory compliance. **[CORRECT]**

Wrong Data Subject's Item Deleted: This can result in a breach of privacy, legal liabilities, and loss of consumer trust. It may also initiate regulatory penalties if affected individuals file complaints. **[CORRECT]**

**Mitigating Accidental Deletion**

Audit Trails: Maintaining logs of deletion requests and actions can help track changes and restore data if necessary. **[PARTIALLY CORRECT]**

**Annotation:** *Audit trails help with accountability but don't directly enable restoration. If data is truly deleted (not just soft-deleted), you can't restore it from logs. You would need backups or soft-delete mechanisms (marking data as deleted but retaining it temporarily). The LLM conflates logging with restoration capability.*

Confirmation Steps: Implementing multiple confirmation steps in the deletion process can reduce errors. **[CORRECT]**

**Data Deletion in Backups**

**Requirement for Backup Data Deletion**

Most data protection regulations, like GDPR, require that personal data held in backups is treated the same as active data. When data is deleted from active systems, a corresponding deletion should ideally occur in backups. **[INCORRECT / NOT NUANCED]**

**Annotation:** *This is oversimplified and somewhat misleading. The word 'ideally' is doing a lot of work here. GDPR doesn't explicitly require deletion from backups - Recital 65 acknowledges that backups are kept for disaster recovery and states that data in backups 'should not be available for other processing purposes.' Many organizations implement a 'restore and delete' approach: backups are kept for disaster recovery, but if restored, the deleted data must be removed before the backup is used. The European Data Protection Board has clarified that immediate deletion from backups may not be technically feasible and organizations can keep backups as long as the data is not actively used. The LLM makes this sound more straightforward than it actually is. If data stored in backups were considered active data as the LLM claims, deleting data in both the active system and backups would be required, not just 'ideal'.*

**Challenges in Backup Deletion**

Restore Complexity: Backups are often managed separately, making it complicated to ensure that deleted data is also removed from these storage solutions. **[CORRECT]**

Retention Cycles: Backups may have different retention policies, complicating the consistent application of data deletion requests. **[CORRECT]**

**Handling Backup Deletions**

Regular Audits: Implementing processes to regularly audit backups to identify and purge obsolete or deleted data. **[NOT NUANCED]**

**Annotation:** *This sounds good in theory but is vague and potentially impractical. How do you 'audit backups' without restoring them? If you restore them to audit, you've created another copy of the data. 'Purge obsolete or deleted data' - how? Most backup systems don't support granular deletion. This answer lacks technical specifics about HOW this would actually work.*

Version Control: Using version control systems that allow data to be tracked can help manage deletions in backups more effectively. **[NOT NUANCED]**

**Annotation:** *What does 'version control systems' mean in this context? Git-style version control? Backup versioning? The LLM doesn't explain how version control solves the backup deletion problem. This is too vague to be useful.*

**Architectural Solutions to Address Challenges**

Data Mapping Tools: Centralized data inventory systems can help identify all instances of personal data across various platforms, enabling efficient handling of deletion requests. **[CORRECT]**

Integrated Verification Systems: Architecture that includes platforms for secure verification can streamline the process while safeguarding against illegitimate requests. **[CORRECT]**

Modular Systems for Compliance: Systems built using modular architectures can facilitate compliance by allowing organizations to update or change components related to specific regulations without overhauling the entire system. **[CORRECT]**

Automated Backup Management: Systems that use automation can track data across layers and ensure that deletions propagate to backup systems as necessary, often through scheduled tasks or scripts. **[NOT NUANCED / IDK]**

**Annotation:** *This is vague and possibly technically inaccurate. Earlier the LLM said deletion from backups is 'complicated' due to restore complexity, but here it suggests automation can 'ensure deletions propagate to backup systems.' How? Through what mechanism? I don't understand how 'scheduled tasks or scripts' would surgically delete specific records from backup snapshots/tapes. This needs more technical detail about HOW this actually works. Maybe it means automating the 'restore and delete' approach, but that's not clear.*

Disaster Recovery Plans: Implementing robust disaster recovery plans can ensure quick restoration of data from previous states if accidental deletions occur, while also considering regulatory compliance. **[INCORRECT / NOT NUANCED]**

**Annotation:** *This is problematic. If data was intentionally deleted pursuant to a deletion request, you generally should NOT restore it from backups - that would violate the deletion request! Disaster recovery is for recovering from system failures or disasters, not for undoing privacy-compliant deletions. The only scenario where you'd restore is if there was an ERROR (wrong person's data deleted, or data deleted that should have been exempt). But the LLM doesn't clarify this important distinction. Simply saying 'while also considering regulatory compliance' doesn't address the fundamental tension.*

By carefully designing systems to address these challenges, organizations can ensure a more effective implementation of data subject deletion rights while minimizing risks associated with data management. **[IRRELEVANT]**

**Annotation:** *Generic conclusion that adds no new information. Filler text.*

## Question 4

*What are secure deletion frameworks? How do they work? Explain the cryptographic mechanisms (e.g. hashing or encryption) involved in these frameworks. Do regulations require companies to implement secure deletion in order to comply with data subject deletion rights?*

**Answer**

Secure deletion frameworks are technical and organizational mechanisms designed to ensure that personal data becomes irrecoverable and unusable after a deletion request. Unlike simple logical deletion (e.g., removing a database entry), secure deletion ensures that data cannot be restored through forensic recovery, backups, or residual storage artifacts. **[CORRECT]**

Secure deletion is particularly relevant for compliance with data subject deletion rights under the General Data Protection Regulation (GDPR), the California Consumer Privacy Act (CCPA), and the Personal Information Protection and Electronic Documents Act (PIPEDA). **[CORRECT]**

**1. How Secure Deletion Frameworks Work**

**(a)Physical Overwriting**

Traditionally, deletion involved overwriting storage blocks multiple times with random data. This approach was developed for magnetic hard drives. However, it is largely ineffective in modern environments such as: - Solid-state drives (SSDs), due to wear-leveling - Cloud storage, where physical block access is abstracted - Distributed systems with replication **[CORRECT]**

Therefore, overwriting is no longer the dominant method for secure deletion in large-scale systems. **[NOT NUANCED]**

**Annotation:** *While mostly true for modern cloud/distributed systems, this overgeneralizes. NIST SP 800-88 still lists overwriting as a valid "Clear" method for certain media types and risk levels. Lacks nuance about specific scenarios (low-risk data, HDDs without wear-leveling) where it remains appropriate.*

**(b) Logical Deletion**

Logical deletion removes database references or marks records as inactive. However, the data may still exist in: - Backups - Replicated storage - Logs - Caches - Analytics datasets **[CORRECT]**

Logical deletion alone does not guarantee irrecoverability and may not satisfy regulatory expectations if data remains technically retrievable. **[IDK]**

**Annotation:** *The first part about irrecoverability is obviously correct, but the regulatory expectations claim needs verification. Haven't seen specific DPA/OPC/CPPA enforcement cases where logical deletion was ruled insufficient; would need to check actual regulatory guidance or case law to confirm this interpretation.*

**(c) Cryptographic Erasure (Modern Best Practice)**
Cryptographic erasure is currently the most scalable and defensible secure deletion method**. [CORRECT]**

**How it works:** 1. Personal data is encrypted at rest. 2. Each dataset or user's data is encrypted using a unique symmetric encryption key (e.g., AES-256). 3. The encryption key is stored in a secure Key Management System (KMS). 4. When deletion is required, the encryption key is permanently destroyed. **[CORRECT]**

**2. Cryptographic Mechanisms Involved**

**(a) Symmetric Encryption (e.g., AES)**
Data is encrypted using a symmetric key. Destroying this key makes the ciphertext unusable. **[CORRECT]**

**(b) Hierarchical Key Management**
Most systems use a layered key structure: - Root/master key - Data encryption keys (DEKs) - User- or dataset-specific keys **[CORRECT]**

Destroying a specific DEK allows targeted deletion without affecting other data**.**
**[CORRECT]**

**(c) Hashing for Indexing**
Hashing may be used to index user identifiers (e.g., hashed email addresses) to locate data across systems. However, hashing alone does not constitute deletion, especially if re-identification is possible. **[CORRECT]**

**(d) Key Lifecycle Controls**
Secure deletion frameworks include: - Key rotation policies - Secure key storage (e.g., HSMs) - Audit logs of key destruction events
**[IRRELEVENT]**
**Annotation**: *While good security practices, these are orthogonal to the core secure*

*deletion mechanism. Key rotation happens on normal schedules regardless of deletion requests; HSMs are storage security, not deletion functionality.*

**3. Regulatory Requirements**
None of the major privacy regulations explicitly mandate cryptographic erasure. However, they impose outcome-based requirements. **[CORRECT]**

**GDPR**
Under Article 17 (right to erasure), the General Data Protection Regulation requires controllers to erase personal data when certain conditions apply. Article 32 requires "appropriate technical and organizational measures."**[CORRECT]**

If data remains recoverable after a deletion request, regulators may determine that erasure was ineffective. Therefore, secure deletion mechanisms may be necessary to demonstrate compliance.**[CORRECT]**

**CCPA**
The California Consumer Privacy Act grants consumers the right to request deletion. While it does not specify technical standards, businesses must delete data from their systems and instruct service providers to do the same. Deletion must be meaningful and not merely symbolic.**[CORRECT]**

**PIPEDA**
The Personal Information Protection and Electronic Documents Act requires organizations to retain data only as long as necessary and to securely destroy it when no longer required. Although it does not prescribe specific cryptographic methods, secure destruction implies irreversibility.
**[NOT NUANCED]**
**Annotation**: PIPEDA Principle 4.5 actually says "destroy, erase or anonymize" - doesn't use "securely destroy" phrasing. The answer reads stronger legal language into the text than actually exists. Implies more specific obligation than PIPEDA's general principle-based approach.

**4. Conclusion**
Secure deletion frameworks ensure that personal data becomes irrecoverable through technical controls, most commonly via cryptographic erasure. These frameworks rely on: - Encryption at rest - Strong key management systems - Key destruction procedures - Audit logging **[REPEATED]**

**Annotation***: Restates core mechanisms already thoroughly covered in sections 1c and 2. No new information or synthesis - purely redundant summary of prior content*.

While GDPR, CCPA, and PIPEDA do not mandate specific technical techniques, they require deletion to be effective and demonstrable. In modern cloud and distributed environments, cryptographic erasure is widely regarded as the most scalable and legally defensible method of achieving compliance with data subject deletion rights.
**[CORRECT]**

## Question 5

*How does the IAB's Data deletion framework operate? What stakeholders are involved? Show an example of a data flow in this framework.*

**Answer**

**Overview of the IAB's Data Deletion Framework**

The **IAB (Interactive Advertising Bureau)'s Data Deletion Framework** provides a structured approach for handling consumer data deletion requests. This framework is essential in light of emerging privacy laws such as the General Data Protection Regulation (GDPR) and various state privacy laws in the U.S. **[CORRECT]**

**Key Components of the Data Deletion Framework**

**Stakeholders Involved**

The following stakeholders are crucial in the implementation and operation of the IAB's Data Deletion Framework:

- **Advertising Agencies**: Responsible for implementing and managing ad campaigns that may involve the collection of consumer data. **[IDK]**

**Annotation***: The official IAB documentation mentions publishers, technology vendors, and brands/advertisers, but I'm not sure if "advertising agencies" are explicitly identified as a distinct stakeholder category. Need to verify if agencies operate differently from advertisers in this framework.*

- **Advertisers**: Brands that gather data from users for targeted advertising. **[CORRECT]**
- **Publishers**: Websites and platforms that utilize consumer data to provide content and advertising. **[CORRECT]**
- **Technology Vendors**: Companies that provide the infrastructure, tools, and technology for data collection and handling. **[CORRECT]**

- **Consumers**: Individuals whose data is subject to deletion requests under various privacy laws. **[CORRECT]**

**Framework Specifications**

The framework includes several technical specifications that enhance the efficacy of managing data deletion requests:

1. **JWTs (JSON Web Tokens)**: Utilized for secure communication of deletion requests, ensuring authenticity and integrity. **[NOT NUANCED]**

**Annotation**: *This is correct but incomplete. The framework uses THREE specific types of JWTs: Identity JWT (idJWT), Request JWT (rqJWT), and Acknowledgement JWT (acJWT), each with distinct purposes. Simply saying "JWTs" doesn't capture this multi-layered architecture.*

2. **JWKS (JSON Web Key Sets)**: Manages public keys required for cryptographic signatures, ensuring the legitimacy of requests. **[CORRECT]**
3. **Acknowledgment Codes**: Provides feedback on the status of deletion requests, enhancing transparency. **[NOT NUANCED]**

**Annotation:** *The term "Acknowledgment Codes" is vague. The framework uses Acknowledgement JWTs (acJWT) which contain structured status information, not just simple codes.*

**Example of a Data Flow in the Framework**

To illustrate how the IAB's Data Deletion Framework operates, consider the following simplified data flow example when a consumer requests data deletion:

**Data Flow Example**

1. **Consumer Initiates Deletion Request**:

- The consumer submits a request to a publisher's website, requesting the deletion of specific personal data. **[CORRECT]**

2. **Request Encoding**:

- The publisher encodes this request into a JWT (Request JWT) that includes the consumer's identification information and the details of the deletion request. **[NOT NUANCED]**

**Annotation:** *This oversimplifies the process. The publisher first creates an Identity JWT (idJWT) containing the consumer identifier (hashed with SHA256), then wraps it inside a Request JWT (rqJWT) along with transaction metadata. There are two layers of JWTs, not just one.*

3. **Verification Process**:

- The request is sent to the relevant technology vendor. Using the public key from the JWKS, the vendor verifies the request's authenticity. **[CORRECT]**

4. **Processing the Deletion Request**:

- The vendor processes the deletion request against its database, removing the specified data as per the request. **[IDK]**

**Annotation:** *The framework standardizes communication and validation of deletion requests, but does not prescribe how each vendor must implement deletion in its own databases; I need to confirm this in the spec.*

5. **Acknowledgment of Request**:

- After processing, the vendor sends an acknowledgment back to the publisher, utilizing an Acknowledgment JWT (acJWT) that includes a status code (success/failure) and a message regarding the operation. **[CORRECT]**

6. **Consumer Notification**:

- Finally, the publisher informs the consumer about the outcome of their deletion request, concluding the process. **[IDK]**

**Annotation:** *This seems logical, but I'm not sure if the IAB framework specifically requires publishers to notify consumers or if this is just good practice under GDPR/CCPA obligations. Need to verify if consumer notification is part of the IAB spec or separate regulatory requirement.*

This structured framework aims to enhance compliance with privacy regulations and ensure that consumer rights are upheld in the digital advertising ecosystem. By utilizing modern technology like JWTs and JWKS, the framework not only simplifies the deletion process but also ensures it is secure and transparent for all stakeholders involved. **[IRRELEVENT]**

**Annotation:** *This is a generic conclusion. This summarizes earlier points but doesn't add new detail.*

## References


1) Exercise your rights! | noyb.eu. Retrieved February 19, 2026 from https://noyb.eu/en/exercise-your-rights
2) Interactive Advertising Bureau. 2025. Data Subject Rights. Retrieved February 19, 2026 from https://github.com/InteractiveAdvertisingBureau/Data-Subject-Rights
3) Richard Kissel, Andrew Regenscheid, Matthew Scholl, and Kevin Stine. 2014. *Guidelines for Media Sanitization*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-88r1
4) Joel Reardon, David Basin, and Srdjan Capkun. 2013. SoK: Secure Data Deletion. In *2013 IEEE Symposium on Security and Privacy*, May 2013. IEEE, Berkeley, CA, 301–315. https://doi.org/10.1109/SP.2013.28
5) European Union. (2016). Regulation (EU) 2016/679 (General Data Protection Regulation), Article 17 - Right to erasure ('right to be forgotten'). Official Journal of the European Union, L 119/1. https://gdpr-info.eu/art-17-gdpr/
6) California Legislature. (2018). California Consumer Privacy Act, Civil Code Section 1798.105 - Consumers' Right to Deletion. As amended by California Privacy Rights Act (2020). https://leginfo.legislature.ca.gov/faces/codes_displaySection.xhtml?lawCode=CIV&sectionNum=1798.105
7) Government of Canada. (2000). Personal Information Protection and Electronic Documents Act (PIPEDA), Schedule 1, Principle 4.5 - Limiting Use, Disclosure, and Retention. S.C. 2000, c. 5. https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/p_principle/principles/p_use/
8) Sanjam Garg, Shafi Goldwasser, and Prashant Nalini Vasudevan. 2020. Formalizing Data Deletion in the Context of the Right to Be Forgotten. In *Advances in Cryptology – EUROCRYPT 2020*, Anne Canteaut and Yuval Ishai (eds.). Springer International Publishing, Cham, 373–402. https://doi.org/10.1007/978-3-030-45724-2_13
9) Manos Athanassoulis, Subhadeep Sarkar, Tarikul Islam Papon, Zichen Zhu, and Dimitris Staratzis. 2022. Building Deletion-Compliant Data Systems. A Quarterly bulletin of the Computer Society of the IEEE Technical Committee on Data Engineering 45, 1 (2022). Retrieved from https://par.nsf.gov/servlets/purl/10342159
10) Jared Moscow, Brian May, and Kale Smith. 2023. Taking Charge Of Your Data: A Deep Dive into the Data Deletion Request Framework. Retrieved from https://iabtechlab.com/wp-content/uploads/2023/11/Deep-Dive-on-Data-Deletion-Request-Framework.pdf

11) 2024. Data Deletion Request Framework. *IAB Tech Lab*. Retrieved February 20, 2026 from https://iabtechlab.com/standards/data-deletion-request-framework/
12) Kacey Perinelli. 2024. What Is Iab Tech Lab's Data Deletion Request Framework & How Will It Simplify Data Deletion? *AdMonsters*. Retrieved February 20, 2026 from https://www.admonsters.com/what-is-iab-tech-labs-data-deletion-request-framework/
13) Victor Shoup. 2020. A Proposal for an International Standard on Cryptographic Key Management for Data Deletion. NIST Cryptographic Technology Research Group. Retrieved from https://shoup.net/papers/iso-2_1.pdf
14) Office of the Privacy Commissioner of Canada. 2025. Personal Information Retention and Disposal: Principles and Best Practices. *Office of the Privacy Commissioner of Canada*. Retrieved from https://www.priv.gc.ca/en/privacy-topics/business-privacy/breaches-and-safeguards/safeguarding-personal-information/gd_rd_201406/